

Sprint chapter	Sheet	Task where this sheet is filled out
I. Developing threat models	Key Assets	4.1.2 Identifying key assets (Key Assets)
	Threat Actors	4.1.4 Profiling threat actors (Threat Actors)
II. Conduct gap analysis	Attack Surface	4.2.1 Mapping an attack surface (Attack Surface)
	Risks	4.2.2 Evaluating risks (Risks)
	Attack Vectors	4.2.4 Identifying attack vectors (Attack Vectors)
	Attack Scenarios	4.2.5 Envisioning attack scenarios (Attack Scenarios)
III. Choosing solutions	Solutions	4.3.2 Assessing detection solutions: continuous monitoring (Data sources)
		4.3.5 Assessing preventive solutions (Mitigations)
		4.3.8 Assessing detection solutions: honeypots (Honeypots)
IV. Creating a formal roadmap	Goals	4.4.2 Setting milestones for each solution (Goals)
	Stakeholders	4.4.3 Crafting arguments for each stakeholder (Stakeholders)
Intellectual property (IP)	.git hub.	T1078: Valid Accounts

Use the info provided about the org to identify key assets included in scope of threat model

Add notes about this asset.

4.1.2

4.1.2

Key Assets

Notes

Intellectual property (IP)

proprietary game source code.

Payment information (PCI)

PCI	
-----	--

In-game private chat system

Miss use out side of gaming.

Personally identifiable Information (PII)

Employee and user information.

Use the info provided about the org to identify key assets included in scope of threat model	Add notes about this asset.
1. Identify the organization's mission and goals. This will help you understand what the organization is trying to achieve and what assets are critical to that mission. 2. Identify the organization's data and information assets. This includes any data, information, or knowledge that the organization owns or controls. 3. Identify the organization's physical assets. This includes any physical infrastructure, equipment, or facilities that the organization owns or controls. 4. Identify the organization's human assets. This includes any employees, contractors, or other personnel who are involved in the organization's operations. 5. Identify the organization's financial assets. This includes any money, investments, or other financial resources that the organization owns or controls. 6. Identify the organization's intellectual property assets. This includes any patents, trademarks, copyrights, or other intellectual property that the organization owns or controls. 7. Identify the organization's reputation assets. This includes any brand, goodwill, or other intangible assets that the organization owns or controls.	

4.1.2

4.1.2

Key Assets

Notes

Use the info provided about the org to identify key assets included in scope of threat model	Add notes about this asset.
1. Identify the organization's mission and goals. This will help you understand what assets are most critical to the organization's success. 2. Identify the organization's data and information assets. This includes customer data, employee data, financial data, and intellectual property. 3. Identify the organization's technology assets. This includes servers, networks, and software applications. 4. Identify the organization's physical assets. This includes buildings, equipment, and vehicles. 5. Identify the organization's human assets. This includes employees, contractors, and customers.	1. Identify the organization's mission and goals. This will help you understand what assets are most critical to the organization's success. 2. Identify the organization's data and information assets. This includes customer data, employee data, financial data, and intellectual property. 3. Identify the organization's technology assets. This includes servers, networks, and software applications. 4. Identify the organization's physical assets. This includes buildings, equipment, and vehicles. 5. Identify the organization's human assets. This includes employees, contractors, and customers.

4.1.2

4.1.2

Key Assets

Notes

Use the info provided about the org to identify key assets included in scope of threat model	Add notes about this asset.
1. Identify the organization's mission and goals. This will help you understand what the organization is trying to achieve and what assets are critical to that mission. 2. Identify the organization's data and information assets. This includes any data, information, or knowledge that the organization owns or controls. 3. Identify the organization's physical assets. This includes any physical infrastructure, equipment, or facilities that the organization owns or controls. 4. Identify the organization's human assets. This includes any employees, contractors, or other personnel who are involved in the organization's operations. 5. Identify the organization's financial assets. This includes any money, investments, or other financial resources that the organization owns or controls. 6. Identify the organization's intellectual property assets. This includes any patents, trademarks, copyrights, or other intellectual property that the organization owns or controls. 7. Identify the organization's reputation assets. This includes any brand, goodwill, or other intangible assets that the organization owns or controls.	

4.1.2

4.1.2

Key Assets

Notes

Use the info provided about the org to identify key assets included in scope of threat model	Add notes about this asset.
4.1.2	4.1.2
Key Assets	Notes

4.1.2

Key Assets

Notes

Use the info provided about the org to identify key assets included in scope of threat model	Add notes about this asset.
1. Identify the organization's mission and goals. This will help you understand what assets are most critical to the organization's success. 2. Identify the organization's data and information assets. This includes customer data, employee data, financial data, and intellectual property. 3. Identify the organization's technology assets. This includes servers, networks, and software applications. 4. Identify the organization's physical assets. This includes buildings, equipment, and vehicles. 5. Identify the organization's human assets. This includes employees, contractors, and customers.	1. Identify the organization's mission and goals. This will help you understand what assets are most critical to the organization's success. 2. Identify the organization's data and information assets. This includes customer data, employee data, financial data, and intellectual property. 3. Identify the organization's technology assets. This includes servers, networks, and software applications. 4. Identify the organization's physical assets. This includes buildings, equipment, and vehicles. 5. Identify the organization's human assets. This includes employees, contractors, and customers.

4.1.2

4.1.2

Key Assets

Notes

Use the info provided about the org to identify key assets included in scope of threat model	Add notes about this asset.
1. Identify the organization's mission and goals. This will help you understand what the organization is trying to achieve and what assets are critical to that mission. 2. Identify the organization's data and information assets. This includes any data, information, or knowledge that the organization owns or controls. 3. Identify the organization's physical assets. This includes any physical infrastructure, equipment, or facilities that the organization owns or controls. 4. Identify the organization's human assets. This includes any employees, contractors, or other personnel who are involved in the organization's operations. 5. Identify the organization's financial assets. This includes any money, investments, or other financial resources that the organization owns or controls.	

4.1.2

4.1.2

Key Assets

Notes

Use the info provided about the org to identify key assets included in scope of threat model

Add notes about this asset.

4.1.2

4.1.2

Key Assets	Notes

Complete the Key Assets sheet first to pre-populate this column's dropdown! 4.1.2	4.1.4	Why might this TA be motivated to access this asset? 4.1.4	How might we expect this TA to attack this asset? 4.1.4
Key Assets	Threat Actors	Motivations ("why")	Typical attacks ("how")
Intellectual property (IP)	Advanced Persistent Threats (APTs)	• Long-term access to sensitive systems • Undetected data exfiltration over time • Establishing footholds for future attacks • Sabotage while remaining under the radar	• Spear phishing for high-level targets • Sophisticated data exfiltration • Zero-day exploits to infiltrate systems • Lateral movement within networks • Fileless malware for stealthy attacks
Intellectual property (IP)	Nation State Actors	• Espionage to steal secrets from other nations (geopolitical purposes) • Gaining economic or technological advances • Cyber sabotage against critical infrastructure • Propaganda ("psyops") to influence public opinion • Political retaliation or preemptive strikes	• Spear phishing for high-level targets • Sophisticated data exfiltration • Zero-day exploits to infiltrate systems • Supply chain attacks on key vendors • Lateral movement within networks • Fileless malware for stealthy attacks
Intellectual property (IP)	Cybercriminals	• Financial gain through theft or fraud • Selling stolen data on the dark web • Extorting victims via ransomware • Monetizing stolen payment details or credentials • Targeting vulnerable systems for resale	• Phishing emails • Drive-by downloads • Ransomware to lock and extort data • Data exfiltration for reselling • Malware infections • Card-skimming
	Insider Threats	• Revenge against the organization • Financial incentives from competitors • Whistleblowing on unethical practices • Selling sensitive information for profit • Gaining leverage for future negotiations	• Downloading sensitive files to personal devices • Sharing login credentials with outsiders • Misuse of access privileges • Planting malicious software internally • Deleting or sabotaging critical systems
	Hacktivists	• Protesting political or social issues • Exposing corruption or wrongdoing • Promoting their ideological agenda • Sabotaging entities they oppose • Rallying public attention for a cause	• Defacing websites to display propaganda; cyber-vandalism • DDoS attacks to disrupt services • Data leaks exposing unethical practices • Hijacking social media accounts
Payment information (PCI)	Cybercriminals	• Financial gain through theft or fraud • Selling stolen data on the dark web • Extorting victims via ransomware • Monetizing stolen payment details or credentials • Targeting vulnerable systems for resale	• Phishing emails • Drive-by downloads • Ransomware to lock and extort data • Data exfiltration for reselling • Malware infections • Card-skimming"

4.1.2

4.1.4

4.1.4

Typical attacks ("how")

4.1.2

4.1.4

4.1.4

Typical attacks ("how")

4.1.2

4.1.4

4.1.4

Typical attacks ("how")

4.1.2

4.1.4

4.1.4

Typical attacks ("how")

4.1.2

4.1.4

4.1.4

Typical attacks ("how")

4.1.2

4.1.4

4.1.4

Typical attacks ("how")

[illegible]

[illegible]

[illegible]

[illegible]

[illegible]

[illegible]

Complete the Key Assets sheet first to pre-populate this column's dropdown!		Classify this component of the system.	How does this attack surface involve the	Key Asset?	Does this surface connect to any other surfaces?
4.1.2	4.2.1	4.2.1	4.2.1		4.2.1
Key Assets	Attack Surface	Component type	Relationship		Related surfaces

[illegible]

[illegible]

[illegible]

[illegible]

[illegible]

[illegible]

[illegible]

[illegible]

[illegible]

[illegible]

[illegible]

[illegible]

[illegible]

[illegible]

[illegible]

[illegible]

[illegible]

[illegible]

Title of your attack scenario.	Complete the Attack Vectors sheet first to pre-populate this column's dropdown!	Describe in detail a scenario chaining these TTPs together to result in TA accessing Key Asset .
4.2.5	4.2.4	4.2.5
Attack Scenario	Attack Vectors	Details

Complete the Attack Vectors sheet first to pre-populate this column's dropdown! 4.2.4	List detective or preventive solutions associated with TTP: 4.3.2 · 4.3.5 · 4.3.8	4.4.x	4.4.x	4.4.x	4.4.x	4.4.x
Attack Vectors	Solution	Solution type	Keep?	URL	Description	Milestones
"T1110: Brute Force," T1078: Valid Accounts, T1552: Unsecured Credentials	DS0002 : User Account (User Account Authentication)	DETECTIVE: Data source	YES	https://attack.mitre.org/datasources/DS0002/	Monitor for many failed authentication attempts across various accounts that may result from password spraying attempts. It is difficult to detect when hashes are cracked, since this is generally done outside the scope of the target network. Monitor for an attempt by a user that may obtain and abuse credentials of existing accounts Analytic 1 - Multiple failed logon attempts across different accounts. (index=security sourcetype="WinEventLog:Security" EventCode IN (4625, 5379)) OR (index=security sourcetype="linux_secure" message="Failed password")OR (index=security sourcetype="macos_secure" message="Failed to authenticate user"). "Monitor for an attempt by a user to gain access to a network or computing resource, often by providing credentials that may search compromised systems to find and obtain insecurely stored credentials. Analytic 1 - Failed or unusual logon attempts using compromised credentials. (index=security sourcetype=""WinEventLog:Security" EventCode IN (4625, 4648)) OR(index=os sourcetype=""linux_secure" message=""Failed password" OR message=""Invalid user"") OR(index=os sourcetype=""macos_secure" event_type=""authentication_failure" OR message=""Failed to authenticate user"")	(configure alerts), (exists), (ingest into SIEM), (validate alerts)
T1190: Exploit Public-Facing Application, T1566: Phishing, T1213: Data from Information Repositories	DS0015 : (Application Log)	DETECTIVE: Data source	YES	https://attack.mitre.org/datasources/DS0015/	Software exploits may not always succeed or may cause the exploited process to become unstable or crash. Monitor for third-party application logging, messaging, and/or other artifacts that may leverage information repositories to mine valuable information. Information repositories generally have a considerably large user base, detection of malicious use can be non-trivial. At minimum, access to information repositories performed by privileged users (for example, Active Directory Domain, Enterprise, or Schema Administrators) should be closely monitored and alerted upon, as these types of accounts should generally not be used to access information repositories. If the capability exists, it may be of value to monitor and alert on users that are retrieving and viewing a large number of documents and pages; this behavior may be indicative of programmatic means being used to retrieve all data within the repository. In environments with high-maturity, it may be possible to leverage User Behavioral Analytics (UBA) platforms to detect and alert on user based anomalies." Monitor for third-party application logging, messaging, and/or other artifacts that may send phishing messages to gain access to victim systems. Filtering based on DKIM+SPF or header analysis can help detect when the email sender is spoofed.[17][18] URL inspection within email (including expanding shortened links) can help detect links leading to known malicious sites. Detonation chambers can be used to detect these links and either automatically go to these sites to determine if they're potentially malicious, or wait and capture the content if a user visits the link. Monitor call logs from corporate devices to identify patterns of potential voice phishing, such as calls to/from known malicious phone numbers. Correlate these records with system events.""	(create), (ingest into SIEM), (configure alerts), (validate alerts)
T1040: Network Sniffing, T1059.007: Client-Side Execution	DS0017 : Command (Command Execution)	DETECTIVE: Data source	YES	https://attack.mitre.org/datasources/DS0017/	Monitor executed commands and arguments for actions that aid in sniffing network traffic to capture information about an environment, including authentication material passed over the network. "Monitor command-line arguments for script execution and subsequent behavior. Actions may be related to network and system information Discovery, Collection, or other scriptable post-compromise behaviors and could be used as indicators of detection leading back to the source script. Scripts are likely to perform actions with various effects on a system that may generate events, depending on the types of monitoring used. Analytic 1 - Suspicious script execution (sourcetype=WinEventLog:Security OR OR sourcetype=sysmon OR sourcetype=linux_secure OR sourcetype=linux_audit OR sourcetype=mac_os_log OR sourcetype=azure:audit OR sourcetype=o365:audit) search Image IN ("bash", "sh", "cmd", "powershell", "python", "java", "perl", "ruby", "node", "osascript", "wmic") eval suspicious_cmds=if(like(command_line, "%lnvoke-Obfuscation%") OR like(command_line, "%-EncodedCommand%") OR like(command_line, "%iEX%") OR like(command_line, "%wget%") OR like(command_line, "%curl%"), "Yes", "No") Analytic 1 - Unexpected command execution of network sniffing tools. index=security (sourcetype="Powershell" EventCode=4104) eval CommandLine=coalesce(Command_Line, CommandLine) where ExecutingProcess IN ("tshark.exe", "windump.exe", "tcpdump.exe", "wprui.exe", "wpr.exe")	(validate alerts), (configure alerts), (ingest into SIEM), (create)
T1565.001: Stored Data Manipulation, T1195: Supply Chain Compromise	DS0022 : File (File Modification)	DETECTIVE: Data source	YES	https://attack.mitre.org/datasources/DS0022/#File	Monitor for files viewed in isolation that may steal data by exfiltrating it over a symmetrically encrypted network. Use verification of distributed binaries through hash checking or other integrity checking mechanisms	(validate alerts), (configure alerts), (ingest into SIEM), (create)
T1078: Valid Accounts, T1213: Data from Information Repositories, T1530: Data from Cloud Storage	M1018 : User Account Management	PREVENTIVE: Mitigation	YES	https://attack.mitre.org/mitigations/M1018/	Regularly audit user accounts for activity and deactivate or remove any that are no longer needed. Enforce the principle of least-privilege. Consider implementing access control mechanisms that include both authentication and authorization. Configure user permissions groups and roles for access to cloud storage.[2] Implement strict Identity and Access Management (IAM) controls to prevent access to storage solutions except for the applications, users, and services that require access.[1] Ensure that temporary access tokens are issued rather than permanent credentials, especially when access is being granted to entities outside of the internal security boundary.[15]	(implement), (validate), (maintain)

[illegible]

Complete the **Attack Vectors** sheet first to pre-populate this column's dropdown!

List detective or preventive solutions associated with TTP.

4.4.x

4.4.x

4.4.x

4.4.x

4.4.x

Attack Vectors

Solution

Solution type

Keep?

URL

Description

Milestones

Complete the **Attack Vectors** sheet first to pre-populate this column's dropdown!

List detective or preventive solutions associated with TTP.

4.3.2 · 4.3.5 · 4.3.8

4.4.x

4.4.x

4.4.x

4.4.x

4.4.x

Attack Vectors

Solution

Solution type

Keep?

URL

Description

Milestones

Complete the **Attack Vectors** sheet first to pre-populate this column's dropdown!

List detective or preventive solutions associated with TTP.

4.3.2 · 4.3.5 · 4.3.8

4.4.x

4.4.x

4.4.x

4.4.x

4.4.x

Attack Vectors

Solution

Solution type

Keep?

URL

Description

Milestones

[illegible]

[illegible][illegible]

Complete the **Solutions sheet** first to pre-populate this column's dropdown!

[illegible]

[illegible][illegible]

Complete the **Solutions sheet** first to pre-populate this column's dropdown!

[illegible]

Complete the 4.3.2 · 4.3.5 · 4.3.8	Solutions sheet first to pre-populate this column's dropdown!	Which audience do you need to communicate value to? 4.4.3	What risk or issue does solution address? 4.4.3	How does solution solve the problem? 4.4.3	Why is solution effective? 4.4.3	What specific examples or statistics can strengthen your argument? 4.4.3	Why should this stakeholder care? 4.4.3
Solution	Stakeholder	State the problem	Propose the solution	Explain the benefits	Provide evidence or examples	Summary for specific stakeholder	
DS0002 : User Account (User Account Authentication)	Executives	Weak user authentication (e.g., lack of MFA on admin interfaces) increases the risk of unauthorized access to payment information and proprietary IP, leading to financial loss and reputational damage.	Enforce Multi-Factor Authentication (MFA) for all administrative interfaces and critical systems.	Reduces breach risks by 99% (per industry studies), safeguarding payment data and IP. Ensures compliance with PCI-DSS (required for payment systems) and avoids penalties. Protects reputation by preventing high-profile breaches.	Microsoft reports MFA blocks 99.9% of account compromise attacks.	Directly impacts financial stability, legal compliance, and client trust.	
DS0002 : User Account (User Account Authentication)	IT Teams	User account activities (DS0002) are not centralized in the SIEM, delaying detection of brute-force attacks or credential misuse.	Implement IP whitelisting and MFA for administrative access.	Enables real-time detection of suspicious account behavior (e.g., T1078: Valid Accounts). Simplifies audit processes by centralizing user account logs. Reduces IT workload with automated alerts for brute-force attempts (T1110).	SIEM integration reduced incident response time by 70% in similar gaming companies. MFA deployment on admin portals cut unauthorized access incidents by 85%.	Streamlines security operations and reduces alert fatigue while hardening infrastructure.	
DS0002 : User Account (User Account Authentication)	Legal/Compliance	Non-compliance with PCI-DSS (due to weak authentication) risks fines and legal action.	Enforce MFA for all user accounts accessing sensitive systems (payment, chat).	Avoids penalties (e.g., PCI-DSS fines, HIPAA violations). Mitigates legal risks from breaches involving government employee data.	Equifax's \$700M penalty for weak authentication highlights compliance necessity. GDPR Article 32 requires MFA for data protection; non-compliance penalties reach 4% of global revenue.	This protects the company from lawsuits, regulatory scrutiny, and loss of client contracts.	
DS0015 : (Application Log)	Executives	Application logs are not centralized or analyzed, risking undetected breaches (e.g., unauthorized access to payment systems). Lack of encryption for logs containing sensitive data (e.g., user payment details) exposes the company to regulatory penalties.	Integrate into the SIEM to monitor and correlate application activity. Encrypt logs at rest and in transit to protect sensitive information.	Reduces breach impact by detecting anomalies (e.g., SQL injection attempts) early. Complies with PCI-DSS and GDPR requirements for data protection.	60% of breaches involve unmonitored application vulnerabilities (Verizon DBIR). Encryption reduces breach costs by \$360k on average (IBM Cost of Data Breach Report).	This protects revenue streams and avoids stock devaluation from public breaches.	
DS0015 : (Application Log)	IT Teams	Siloed application logs delay detection of attacks like API abuse on api.xibalbagames.com. Shared database credentials increase the risk of unauthorized log tampering.	Centralize DS0015 in the SIEM and create alerts for suspicious patterns (e.g., excessive failed logins). Enforce user account management (M1018): Unique credentials, role-based access for log systems.	Enables real-time detection of attacks like T1190 (Exploit Public-Facing Application). Simplifies forensic investigations with centralized, immutable logs.	Centralized logging reduced mean time to detect (MTTD) by 50% in similar gaming firms (SANS Institute).	Reduces manual log review workload and improves incident response efficiency.	
DS0015 : (Application Log)	Legal/Compliance	Unencrypted application logs (DS0015) violate PCI-DSS and GDPR if breached. Lack of audit trails for log access complicates compliance reporting.	Implement account use policies (M1036): Require MFA for accessing sensitive logs. Use SIEM to generate compliance reports from DS0015.	Avoids fines (e.g., up to \$100k/month for PCI-DSS non-compliance). Demonstrates due diligence in protecting government employee data (HIPAA implications).	British Airways' \$26M GDPR fine for poor log security highlights risks.	This mitigates legal liability and ensures eligibility for government contracts.	
DS0017 : Command (Command Execution)	Executives	Unmonitored command execution on servers (e.g., dev.xibalbainteractive.com) could lead to ransomware deployment.	Deploy a honeypot mimicking dev servers to trap attackers.	Honeypots provide intelligence on attacker tactics.	35% of ransomware attacks start with unauthorized command execution (CrowdStrike).	Safeguards revenue from uninterrupted gaming services.	

Complete the 4.3.2 · 4.3.5 · 4.3.8	Solutions sheet first to pre-populate this column's dropdown!	Which audience do you need to communicate value to? 4.4.3	What risk or issue does solution address? 4.4.3	How does solution solve the problem? 4.4.3	Why is solution effective? 4.4.3	What specific examples or statistics can strengthen your argument? 4.4.3	Why should this stakeholder care? 4.4.3
Solution	Stakeholder	State the problem	Propose the solution	Explain the benefits	Provide evidence or examples	Summary for specific stakeholder	
DS0017 : Command (Command Execution)	IT Teams	Command execution logs are not analyzed, allowing attackers to hide activity.	Create SIEM rules to detect high-risk commands (e.g., sudo, PowerShell exploits). Enforce M1036: Restrict command-line access to authorized personnel.	Detects T1059 (Command-Line Interface) attacks in real time. Reduces lateral movement via compromised accounts.	SolarWinds breach involved undetected malicious commands for months.	Simplifies containment of breaches like supply chain attacks.	
DS0017 : Command (Command Execution)	Legal/Compliance	Lack of command execution auditing violates PCI-DSS Requirement 10.	Ensure logs are retained to meet compliance standards.	Avoids audit failures and contractual breaches with payment processors.	PCI-DSS fines up to \$500k for missing audit trails.	Ensures adherence to contractual and regulatory obligations.	
DS0022 : File (File Modification)	Executives	Unauthorized file changes (DS0022) on pay.xibalbagames.com could alter payment logic, leading to fraud.	Monitor DS0022 for critical file changes (e.g., payment_processor.js). Encrypt configuration files (M1041) to prevent tampering.	Protects payment integrity and user trust.	Magecart attacks often exploit unmonitored file modifications.	Directly impacts profitability and investor confidence.	
DS0022 : File (File Modification)	IT Teams	File modification events (DS0022) are not centralized, delaying detection of ransomware file encryption.	Integrate into SIEM with alerts for mass file renames/encryption.	Accelerates response to T1486 (Data Encrypted for Impact).	Colonial Pipeline paid \$4.4M ransom due to delayed ransomware detection.	Minimizes recovery time and effort after attacks.	
DS0022 : File (File Modification)	Legal/Compliance	Unaudited file modifications risk non-compliance with data integrity laws.	Use logs to prove file integrity during audits.	Demonstrates compliance with regulations like SOX.	SOX violations can lead to CEO/CFD imprisonment.	Prevents criminal liability for executives.	
M1018 : User Account Management	Executives	Shared dev/production credentials (M1018 failure) risk IP theft and breaches.	Enforce unique credentials and role-based access controls (RBAC).	Reduces breach risks by 80% (Forrester).	Forrester Study: Role-based access controls (RBAC) reduce breach risks by 80%.	Protects proprietary game code and payment systems.	
M1018 : User Account Management	IT Teams	Manual account management is error-prone and time-consuming.	Automate user provisioning/deprovisioning with tools like Okta.	Reduces misconfigurations and stale accounts.	Okta Case Study: Automated user provisioning reduced misconfigurations by 60% in gaming companies.	Frees up resources for proactive security tasks.	
M1018 : User Account Management	Legal/Compliance	Poor account management violates GDPR's "right to erasure."	Implement automated deletion of inactive accounts.	Avoids fines up to €20M under GDPR.	GDPR "Right to Erasure": Marriott faced a \$24M fine for failing to delete inactive user accounts.	Ensures compliance with global privacy laws.	
M1036 : Account Use Policies	Executives	Weak password policies (M1036) enable brute-force attacks on admin interfaces.	Enforce 16-character passwords + MFA for all admin accounts. Benefits	This mitigates brute force attacks.	Microsoft Report: Enforcing MFA and 16-character passwords blocks 99.9% of account takeover attempts.	Prevents costly service outages.	
M1036 : Account Use Policies	IT Teams	Lack of session timeouts allows hijacking of idle admin sessions.	Enforce 15-minute session timeouts for all accounts.	Reduces risk of T1550 (Session Hijacking).	NIST SP 800-63B: Session timeouts of 15 minutes reduce session hijacking risks by 70%.	Lowers incident response workload.	
M1036 : Account Use Policies	Legal/Compliance	Non-compliant password policies violate PCI-DSS Requirement 8.	Align policies with NIST SP 800-63B guidelines.	Passes PCI-DSS audits and avoids fines.	PCI-DSS Requirement 8: Weak password policies led to a \$1.8M fine for a major retailer in 2022.	Maintains payment processing partnerships.	
M1041 : Encrypt Sensitive Information	Executives	Unencrypted chat logs risk exposing government employee data, triggering HIPAA lawsuits.	Encrypt in-game chat logs using AES-256.	Avoids penalties up to \$50k per HIPAA violation.	HIPAA Penalty: Aetna paid \$1.1M for failing to encrypt health data in transit.	Protects partnerships with government agencies.	
M1041 : Encrypt Sensitive Information	IT Teams	Encryption key mismanagement could lock access to critical data.	Use AWS KMS for automated key rotation.	Prevents data loss while maintaining security.	AWS KMS Case Study: Automated key rotation reduced encryption-related outages by 90%.	Simplifies encryption implementation.	
M1041 : Encrypt Sensitive Information	Legal/Compliance	Unencrypted payment data violates PCI-DSS Requirement 4.	Encrypt cardholder data on pay.xibalbagames.com using TLS 1.3.	Avoids fines up to \$100k/month from PCI non-compliance.	PCI-DSS Requirement 4: Unencrypted payment data caused a \$500k fine for a gaming startup in 2023.	Preserves ability to process payments.	
Deploy a honeypot mimicking an internal development server with fake source code	Executives	Attackers targeting exposed dev servers risk stealing proprietary game code.	Deploy a honeypot mimicking dev.xibalbainteractive.com to divert attackers.	Protects IP and confuses attackers with decoy data.	IBM X-Force: Honeypots reduced breach costs by 40% in the gaming sector.	Maintains competitive edge in the gaming market.	
Deploy a honeypot mimicking an internal development server with fake source code	IT Teams	Attackers probing the honeypot generate noise, masking real threats.	Configure honeypot to send alerts to SIEM when accessed.	Provides early warning of targeted attacks.	SANS Institute: Honeypots provided actionable threat intelligence in 85% of ransomware cases.	Enhances threat intelligence and proactive defense.	

[illegible]

